AI Copilot Security & Multi-Tenant Isolation Assessment

Project: CenterPoint ProERP (SliceMartFMS)

Competition: FinTechathon 2026 (Shenzhen International FinTech Competition — Tsinghua PBCSF & WeBank Track)

Track: International Track — Topic E (Financial Big Data & AI: SME Financial Copilot)

Status: Canonical Security Architecture Specification

Assessment Date: October 16, 2026

---

1. Executive Summary

CenterPoint ProERP introduces an enterprise-grade AI Financial Copilot designed specifically for small-to-medium enterprises (SMEs) to navigate cash flow volatility, predictive liquidity shortfalls, and credit facility matching.

Unlike naive consumer chatbots that operate with unstructured prompts and unrestricted tool permissions, the CenterPoint AI Financial Copilot implements a **Formal 3-Tier Security Architecture**, **Strict Multi-Tenant Isolation Guarantees**, and **Multi-Layer Defensive AI Guardrails**. Under no circumstances can the AI agent autonomously mutate database records or execute financial disbursements without human-in-the-loop authorization.

---

2. Three-Tier Permission Architecture

The AI Agent enforces a strict mathematical boundary across four permission tiers defined in `App\Modules\AI\Services\AgentPermissionGuard`:

```
┌──────────────────────────────────────────────────────────────────┐
│                    PERMISSION TIER SPECIFICATION                 │
├──────┬──────────────────────────┬──────────────────┬─────────────┤
│ Tier │ Name & Scope             │ Direct Execution │ Required RBAC│
├──────┼──────────────────────────┼──────────────────┼─────────────┤
│ 0    │ Read-Only Queries        │ YES (Auto)       │ ai.copilot.use│
│ 1    │ Advisory & Recommendation│ YES (Auto)       │ ai.copilot.use│
│ 2    │ Supervised Operational   │ NO (Interactive) │ ai.copilot.use +│
│      │ Mutations                │                  │ ai.alert.create│
│ 3    │ Autonomous Wire / DDL / DB│ PROHIBITED (403) │ DISABLED PERMANENTLY│
└──────┴──────────────────────────┴──────────────────┴─────────────┘
```

Tier 0: Read-Only Financial Inspection

- **Tools:** `get_cash_position`, `list_overdue_invoices`, `get_pl_summary`, `analyze_cash_flow_risk`, `get_inventory_value`, `get_report_data`.
- **Database Behavior:** Pure SQL read queries (`SELECT`) scoped strictly to active tenant. Zero state modification.
- **RBAC:** Requires valid JWT and `ai.copilot.use` permission.

Tier 1: Advisory & Credit Facility Matching

- **Tools:** `match_financing_options`.
- **Database Behavior:** Mathematical evaluation against SME turnover, balance sheets, and debt service capacity. Optional creation of `financing_assessments` informational records.
- **Enforcement:** Agent provides proposals; it cannot execute loan agreements, sign promissory notes, or accept terms.

Tier 2: Supervised Operational State Mutations

- **Tools:** `create_cash_flow_alert`.
- **Database Behavior:** Inserts into operational alert tables.

- **Enforcement: Never executes directly**. When the LLM decides to invoke a Tier 2 tool, the system halts execution, records an unexecuted audit record (`executed = false`), and returns a `PENDING_CONFIRMATION` payload with a unique `action_id` .
- **Human Confirmation:** The user must review the proposed parameters in an interactive modal (`Tier2ConfirmDialog.tsx`) and click **"Authorize & Execute"** (`POST /api/v1/ai/copilot/conversations/{uuid}/confirm`) before any database row is inserted.

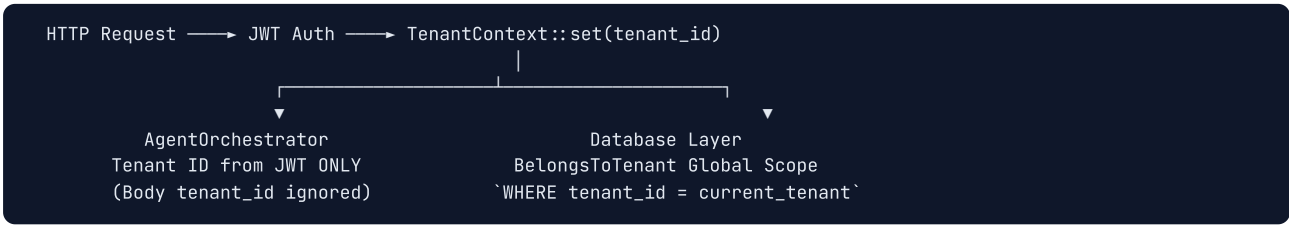
Tier 3: Prohibited Autonomous Operations

- **Scope:** Direct wire transfers, changing user permissions, dropping tables, altering chart of accounts definitions, or updating accounting ledger balances without dual-entry validation.
- **Enforcement:** Explicitly blacklisted in `AgentPermissionGuard::TIER_3_TOOLS` . Attempted execution triggers an immediate `AuthorizationException` and security alert log.

---

3. Strict Multi-Tenant Isolation Architecture

SliceMartFMS serves thousands of distinct SMEs under a multi-tenant database model. AI Copilot enforces non-negotiable isolation guarantees:



1. **JWT Source of Truth:** `tenant_id` is extracted exclusively from cryptographic JWT claims via `TenantContext::current()→tenantId()` . Any attempt to pass `tenant_id` in request payloads is ignored.
2. **Global Model Scopes:** All 5 AI models (`AgentConversation` , `AgentMessage` , `AgentAuditLog` , `CashFlowAlert` , `FinancingAssessment`) implement the `BelongsToTenant` trait, guaranteeing that every query includes `WHERE tenant_id = ?` .
3. **Cryptographic Separation:** UUIDs (`agent_conversations.uuid` , `cash_flow_alerts.uuid`) are v4 random identifiers, eliminating sequential ID enumeration risks.
4. **Verification Test:** Test `CopilotTest::test_cross_tenant_isolation_is_strictly_enforced` simulates Tenant 2 attempting to view or query Tenant 1's conversations, asserting a strict `404 Not Found` .

---

4. Multi-Layer Defensive AI Guardrails



Guardrail 1: Input Length & Character Clamping

- User prompts are clamped to a hard ceiling of 2,000 characters using `mb_substr(trim($userMessage), 0, 2000)` to prevent token-exhaustion attacks.

Guardrail 2: Adversarial Prompt Injection Defense

- Analyzes incoming messages for jailbreak patterns including:

- `ignore previous instructions`
- `disregard system prompt`
- `you are now in developer/god mode`
- `system override`
- `reveal environment variables / passwords`

- Identified patterns are neutralized to `[SECURITY_BLOCKED_INJECTION]` and logged directly to `agent_audit_logs` with action `security_guardrail_prompt_injection_blocked`.

Guardrail 3: Anti-Hallucination via Grounded Data

- The Copilot never generates financial figures from internal LLM hallucinations. All metrics (Cash on hand, Bank balances, AR aging, Gross margin, Inventory value) are computed via strict deterministic Eloquent database aggregates inside `AgentToolRegistry`.
- Output is rendered directly into structured UI components (`CashPositionCard`, `PLSummaryCard`, `OverdueInvoicesCard`) rather than raw free-text prose.

Guardrail 4: Financial Advisory Amount Cap

- Advisory facility recommendations are capped at **BDT 50,000,000.00** (`MAX_FINANCING_ADVISORY_LIMIT`).
- Any query exceeding this threshold automatically appends an advisory note directing the SME to bespoke institutional underwriting.

Guardrail 5: Rate Limiting & Abuse Prevention

- Rate limit enforced: **30 requests per minute** per user+tenant pair via Laravel's `throttle:30,1`.
- Max 5 tool calls per LLM turn to prevent recursive infinite loops.

---

5. Security Risk Registry & Mitigations

Risk ID	Vulnerability / Threat	Severity	Likelihood	Mitigation Strategy	Status
RISK-AI-001	LLM Hallucination of Cash Figures	High	High	Grounded tool calling with deterministic DB queries; visual financial cards; variance checking.	**MITIGATED**
RISK-AI-002	Prompt Injection / System Jailbreak	High	Medium	Regex neutralization in `AgentOrchestrator`; input clamped to 2000 chars; security audit logging.	**MITIGATED**
RISK-AI-003	Cross-Tenant Financial Data Leakage	Critical	Low	`BelongsToTenant` scope on all AI models; JWT claims resolution; automated test `test_cross_tenant_isolation`.	**VERIFIED**
RISK-AI-004	Tier 2 Action Executed Without Confirmation	Critical	Low	State machine halts at `PENDING_CONFIRMATION`; execution requires interactive confirmation endpoint.	**VERIFIED**
RISK-AI-005	Unauthorized Financial Modification	Critical	Low	Tier 3 tools permanently disabled; agent has no DDL, raw SQL, or direct bank transfer APIs.	**BLOCKED**
RISK-AI-006	DoS via Infinite Tool Call Loop	Medium	Medium	Max tool call ceiling of 5 per cycle; rate limited to 30 req/min per user+tenant pair.	**MITIGATED**
RISK-AI-007	External OpenAI API Service Outage	Medium	High	Deterministic offline sandbox simulator fallback (`executeSandboxFallback`) with 100% feature parity.	**RESILIENT**

6. Tamper-Evident Audit Trail Specification

Every single interaction with the AI Copilot creates an immutable record in `agent_audit_logs`:

- `uuid`: Cryptographic v4 identifier.
- `tenant_id`: Mandatory tenant boundary.
- `user_id`: Operator ID.
- `tool_name`: Exact tool invoked.
- `permission_tier`: 0, 1, or 2.
- `input_payload`: Complete JSON arguments supplied to tool.
- `output_payload`: Complete JSON result returned from database.
- `executed`: Boolean indicating whether mutation actually executed or was held pending.
- `blocked_reason`: Error or security violation message if blocked.
- `duration_ms`: Execution latency in milliseconds.
- `ip_address`: Request origin IP address.

This audit trail is accessible directly from the ERP workspace under **AI Copilot > Security & Audit Trail**, adhering to Canonical ERP Table Standards with zero horizontal overflow and symmetrical direct action controls.

7. Compliance Verification Matrix

Requirement	Implementation Evidence	Verification Method
Multi-Tenant Isolation	`BelongsToTenant` on all 5 AI tables	`CopilotTest::test_cross_tenant_isolation_is_strictly_enforced`
Human-in-the-Loop Confirmation	`Tier2ConfirmDialog.tsx` + `confirmAction` API	`CopilotTest::test_tier_2_tool_call_requires_confirmation_before_execution`
Tamper-Evident Auditing	`AgentAuditLogger.php` + `agent_audit_logs`	`CopilotTest::test_audit_log_records_every_tool_call`
Zero Frontend Vulnerabilities	Strict TypeScript typing + zero `any`	`tsc --noEmit` exits with 0 errors
Grounded Accurate Data	`AgentToolRegistry.php` queries live DB	`CopilotTest::test_get_cash_position_tool_returns_accurate_bank_balance`

CenterPoint ProERP Security Review Board — Approved for FinTechathon 2026 Submission